ELENCO MINACCE COMUNI CHE POSSONO COLPIRE UN'AZIENDA

Documento basato sul Rapporto Clusit 2025 e best practices di cybersecurity

1. **MALWARE** (38% degli attacchi in Italia - 2024)

Descrizione

Software dannoso progettato per infiltrarsi, danneggiare o compromettere sistemi informatici.

Come funziona

- Si diffonde attraverso email infette, download compromessi, exploit kit o dispositivi USB,
- una volta installato, può eseguire diverse azioni malevole a seconda del tipo.

Tipi principali

Ransomware: cripta i dati e richiede un riscatto per il recupero.
Trojan: si maschera da software legittimo per rubare dati.
Spyware: raccoglie informazioni senza consenso.
Worm: si replica automaticamente attraverso la rete.
Rootkit: nasconde la presenza di altro malware.

Danni potenziali

- Perdita o cifratura dei dati aziendali critici,
- interruzione delle operazioni aziendali (downtime medio: 21 ore),
- costi di ripristino elevati (>300.000€ per PMI secondo Acronis),
- furto di proprietà intellettuale,
- danni reputazionali.

Settori più colpiti

- Manifatturiero (25% degli attacchi globali al settore riguardano l'Italia),
- sanità,
- finanza,
- Pubblica Amministrazione.

2. PHISHING E SOCIAL ENGINEERING

Descrizione
Tecniche di manipolazione psicologica per indurre le vittime a rivelare informazioni sensibili o compiere azioni dannose.

Come funziona
- Email phishing: messaggi fraudolenti che imitano comunicazioni legittime,
- spear phishing: attacchi mirati a specifici individui o organizzazioni,
- vishing: phishing tramite chiamate telefoniche,
- smishing: phishing via SMS,
- business Email Compromise (BEC**)**: impersonificazione di dirigenti per autorizzare pagamenti.

Obiettivi comuni
- Credenziali di accesso (username e password),
- dati bancari e finanziari,
- informazioni riservate aziendali,
- autorizzazione a trasferimenti di denaro.

Danni potenziali
- Compromissione degli account aziendali,
- trasferimenti fraudolenti di denaro,
- furto di identità,
- aaccesso non autorizzato a sistemi critici.

Nota Clusit: 1 attacco su 10 potrebbe essere evitato con migliore formazione del personale

Fattori di rischio
- Scarsa consapevolezza dei dipendenti,
- mancanza di formazione periodica,
- assenza di procedure di verifica per operazioni sensibili.

3. ATTACCHI DDoS

Descrizione
Distributed Denial of Service - sovraccarico intenzionale di server o reti per renderli non disponibili.

Come funziona
- Utilizzo di botnet (reti di dispositivi compromessi),
- invio massiccio di richieste simultanee,
- saturazione della banda o delle risorse del server.

Tipi di attacco DDoS
- **volumetrici**: saturano la banda disponibile,
- **Protocol attacks**: esauriscono le risorse del server,
- **Application layer**: mirano a specifiche applicazioni web.

Danni potenziali
- Interruzione totale dei servizi online,
- perdita di fatturato durante il downtime,
- impossibilità per clienti di accedere ai servizi,
- danno reputazionale,
- costi per mitigazione dell'attacco.

Motivazioni comuni
-Estorsione (richiesta di pagamento per fermare l'attacco),
-Hacktivism (protesta politica/sociale),
- Competizione sleale,
- Diversivo per altri attacchi.

4. FURTO DI DATI (DATA BREACH)

Descrizione

Accesso non autorizzato e sottrazione di dati sensibili, personali o aziendali riservati

Come avviene

- Sfruttamento di vulnerabilità nei sistemi
- Credenziali compromesse
- Insider threat (minacce interne)
- Attacchi alla supply chain
- Configurazioni errate di database o cloud

Dati tipicamente sottratti

- Dati personali di clienti (GDPR)
- Informazioni finanziarie
- Proprietà intellettuale
- Segreti commerciali
- Credenziali di accesso
- Dati sanitari (particolarmente sensibili)

Danni potenziali

- Sanzioni GDPR (fino al 4% del fatturato globale)
- Obblighi di notifica alle autorità e agli interessati
- Class action da parte dei clienti
- Perdita di fiducia dei clienti
- Danni competitivi
- Costi di forensics e remediation

Conseguenze legali

- Violazioni del GDPR
- Responsabilità civile
- Danni reputazionali irreversibili

5. ATTACCHI BASATI SU VULNERABILITÀ

Sfruttamento di falle di sicurezza in software, sistemi operativi o hardware.

Tipi di vulnerabilità

- **Zero-day**: vulnerabilità sconosciute al vendor (aumentate del 90%)
- **Vulnerabilità note non patchate**: falle conosciute ma non corrette
- **Misconfigurazioni**: errori di configurazione che creano falle
- **Vulnerabilità della supply chain**: punti deboli nei fornitori

Come vengono sfruttate

- Exploit kit automatizzati
- Attacchi mirati a software obsoleti
- Scansione automatica di sistemi vulnerabili
- Sfruttamento di plugin e componenti di terze parti

Danni potenziali

- Accesso completo ai sistemi
- Escalation dei privilegi
- Installazione di backdoor
- Movimento laterale nella rete
- Persistenza nell'infrastruttura

Settori particolarmente colpiti

- News/Multimedia (incidenti massicci dovuti a vulnerabilità CMS)
- E-commerce
- Servizi web
- IoT e dispositivi connessi

Prevenzione

- Patch management regolare
- Vulnerability assessment periodici
- Penetration testing
- Sistemi di rilevamento intrusioni (IDS/IPS)

6. ATTACCHI ALLA SUPPLY CHAIN

Descrizione

Compromissione della sicurezza attraverso fornitori, partner o terze parti meno protette.

Come funziona

- Attacco a un fornitore con misure di sicurezza deboli
- Uso dell'accesso del fornitore per infiltrarsi nel target principale
- Compromissione di software/aggiornamenti di terze parti
- Sfruttamento di connessioni VPN di manutenzione

Esempi tipici

- Compromissione di software di gestione IT
- Attacchi attraverso fornitori di servizi cloud
- Manipolazione di aggiornamenti software
- Accessi non monitorati di partner esterni

Danni potenziali

- Compromissione simultanea di multiple organizzazioni
- Diffusione rapida del malware
- Difficoltà di identificazione dell'origine
- Impatto su intere filiere produttive

Fattori di rischio

- Mancanza di due diligence sui fornitori
- Assenza di requisiti di sicurezza nei contratti
- Accessi privilegiati non monitorati
- Connessioni dirette non segmentate

7. RANSOMWARE

Descrizione

Software che cripta i dati aziendali e richiede un pagamento (riscatto) per il ripristino.

Come funziona

1. Infiltrazione nel sistema (phishing, vulnerabilità, RDP esposti)
2. Movimento laterale nella rete
3. Esfiltrazione dei dati (doppia estorsione)
4. Cifratura massiva dei dati
5. Richiesta di riscatto (spesso in criptovalute)
6. Minaccia di pubblicazione dei dati sottratti

Evoluzione recente

- **Ransomware-as-a-Service (RaaS)**: modello di business per affiliati
- **Doppia/tripla estorsione**: cifratura + minaccia pubblicazione + attacco DDoS
- **Attacchi mirati**: non più casuali ma studiati per massimizzare il riscatto

Danni potenziali

- Downtime medio di 21 ore (dato Acronis)
- Costi di ripristino superiori a 300.000€ per PMI
- Perdita permanente di dati se non c'è backup
- Pagamento del riscatto (senza garanzia di recupero)
- Violazioni GDPR per perdita dati
- Interruzione completa del business

Vettori di infezione

- Email di phishing (70% dei casi)
- RDP (Remote Desktop Protocol) esposti e non protetti
- Vulnerabilità di software non aggiornati
- Dispositivi USB infetti

Prevenzione

- Backup 3-2-1 (3 copie, 2 supporti diversi, 1 offsite)
- Autenticazione multifattoriale (MFA)
- Segmentazione della rete
- Monitoraggio continuo
- Formazione anti-phishing

7. MINACCE INTERNE (INSIDER THREATS)

Descrizione

Rischi derivanti da dipendenti, collaboratori o ex-dipendenti con accesso legittimo ai sistemi.

Tipologie

- **Minacce malevole**: dipendenti che deliberatamente danneggiano l'azienda
- **Minacce negligenti**: errori involontari che causano incidenti
- **Credenziali compromesse**: account legittimi usati da attaccanti esterni

Esempi comuni

- Furto di dati prima di lasciare l'azienda
- Sabotaggio di sistemi
- Condivisione di credenziali
- Uso improprio di privilegi di accesso
- Vendita di informazioni a concorrenti

Danni potenziali

- Furto di proprietà intellettuale
- Compromissione di dati sensibili
- Danni reputazionali
- Difficoltà di detection (accessi apparentemente legittimi)

Segnali di allarme

- Accessi insoliti a dati sensibili
- Download massicci di file
- Tentativi di accesso a risorse non pertinenti
- Uso di dispositivi personali non autorizzati

8. ATTACCHI A INFRASTRUTTURE CLOUD E SAAS

Descrizione

Minacce specifiche per ambienti cloud, configurazioni errate e servizi SaaS.

Vulnerabilità comuni

- **Misconfigurazioni**: bucket S3 pubblici, permessi eccessivi
- **Credenziali compromesse**: account cloud non protetti da MFA
- **Account Shadow IT**: servizi cloud non autorizzati
- **API non sicure**: interfacce di programmazione vulnerabili
- **Dati non criptati**: informazioni in chiaro nel cloud

Rischi specifici del cloud

- Condivisione di risorse multi-tenant
- Responsabilità condivisa mal compresa
- Visibilità limitata su configurazioni
- Mancanza di controllo sulle infrastrutture fisiche

Danni potenziali

- Esposizione massiva di dati
- Accessi non autorizzati globali
- Interruzione dei servizi cloud-based
- Costi imprevisti per uso fraudolento

10. MINACCE EMERGENTI CON INTELLIGENZA ARTIFICIALE

Descrizione

Nuova generazione di attacchi potenziati dall'AI e dall'automazione.

Capacità dell'AI negli attacchi

- **Malware adattivo**: codice che modifica comportamento per evitare detection
- **Phishing potenziato**: messaggi più convincenti e personalizzati
- **Deepfake**: video/audio falsificati per social engineering
- **Password cracking**: algoritmi più efficienti per violare credenziali
- **Evasione automatica**: bypass di sistemi di sicurezza

Nuove minacce secondo Clusit 2025

- **AI Agentica**: sistemi autonomi che possono condurre attacchi senza supervisione
- **Memory poisoning**: manipolazione della memoria degli agenti AI
- **Tool misuse**: uso improprio di strumenti AI per scopi malevoli
- Oltre 15 nuovi vettori di rischio catalogati da OWASP

Preoccupazioni principali

- Scalabilità degli attacchi
- Automazione completa delle campagne
- Difficoltà di distinzione tra umano e AI
- Velocità di evoluzione delle minacce

11. ATTACCHI A SISTEMI OT/IoT (Operational Technology / Internet of Things)

Descrizione

Minacce specifiche per sistemi di controllo industriale e dispositivi IoT.

Obiettivi tipici

- SCADA (Supervisory Control and Data Acquisition)
- PLC (Programmable Logic Controllers)
- Sistemi di building automation
- Dispositivi IoT industriali
- Smart devices aziendali

Vulnerabilità specifiche

- Sistemi legacy non aggiornabili
- Protocolli industriali non sicuri
- Connessioni di manutenzione remota non protette
- Dispositivi IoT con credenziali default
- Mancanza di segmentazione rete IT/OT

Danni potenziali

- Interruzione della produzione
- Danni fisici a impianti
- Rischi per la sicurezza fisica
- Sabotaggio industriale
- Spionaggio industriale

12. ATTACCHI GEOPOLITICI E HACKTIVISM (In crescita)

Descrizione

Attacchi motivati da ragioni politiche, ideologiche o stati-nazione.

Caratteristiche

- Motivazioni non economiche
- Spesso mirati a settori strategici
- Possibile supporto statale (APT - Advanced Persistent Threats)
- Obiettivi di destabilizzazione o spionaggio

Obiettivi principali

- Infrastrutture critiche
- Settore governativo (+90% attacchi in Europa nel 2024)
- Settore energetico
- Telecomunicazioni
- Difesa

Tecniche utilizzate

- Campagne di disinformazione
- Defacement di siti web
- Leak di dati sensibili
- DDoS coordinati
- Spionaggio informatico

STATISTICHE CHIAVE - RAPPORTO CLUSIT 2025

Italia

- **10,1%** degli attacchi globali (con solo 1,8% del PIL mondiale)
- **+15,2%** incremento attacchi rispetto al 2023
- **357** incidenti gravi documentati nel 2024
- **78%** attacchi motivati da cybercrime (+14% vs 2023)
- **39%** degli attacchi agli ultimi 5 anni sono avvenuti nel 2024

Globale

- **3.541** attacchi gravi nel 2024 (+27,4% vs 2023)
- **86%** attacchi motivati da cybercrime
- **295** media mensile attacchi (vs 232 del 2023)

Tecniche più utilizzate (Italia 2024)

1. **Malware** - 38%
2. **DDoS** - 21%
3. **Vulnerabilità** - 19% (record storico)
4. **Phishing/Social Engineering** - 11%
5. **Altri** - 11%

Settori più colpiti in Italia

1. News/Multimedia - 17,6%
2. Manifatturiero - 15,7%
3. Multiple Targets - 15,7%
4. Governativo - 10,4%
5. Trasporti/Logistica - 7,3%

RACCOMANDAZIONI ESSENZIALI

1. Strategie di Difesa

- **Formazione continua** del personale (1 attacco su 10 evitabile con training)
- **Patch management** regolare e tempestivo
- **Autenticazione multi-fattore** (MFA) su tutti gli accessi critici
- **Backup 3-2-1** testati regolarmente
- **Segmentazione della rete** IT/OT

2. Monitoraggio e Detection

- **SIEM** (Security Information and Event Management)
- **EDR/XDR** (Endpoint/Extended Detection and Response)
- **Threat Intelligence** per minacce emergenti
- **Vulnerability Assessment** periodici
- **Penetration Testing** almeno semestrale

3. Governance

- **Security by Design** in tutti i progetti
- **Valutazione terze parti** nella supply chain
- **Incident Response Plan** documentato e testato
- **Business Continuity Plan** aggiornato
- **Conformità normativa** (GDPR, NIS2, DORA)

4. Investimenti

- La sicurezza non è un costo ma un **investimento necessario**
- Le aziende con strategie efficaci riducono il rischio dell'**89%**
- I costi di un attacco superano di molto i costi di prevenzione
- Considerare soluzioni **integrate** vs approcci frammentati (-43% violazioni)

CONCLUSIONE

Il panorama delle minacce informatiche nel 2025 è caratterizzato da un aumento costante del numero e della sofisticazione degli attacchi. L'Italia risulta particolarmente esposta rispetto al suo peso economico, subendo il 10,1% degli attacchi globali pur rappresentando solo l'1,8% del PIL mondiale.

Il cybercrime rimane la motivazione dominante dietro gli attacchi (86% a livello globale, 78% in Italia), ma si registra una crescita preoccupante delle minacce legate a finalità geopolitiche e hacktiviste. L'Intelligenza Artificiale si configura come un'arma a doppio taglio, potendo essere utilizzata sia per rafforzare le difese che per condurre attacchi più sofisticati e automatizzati.

Le PMI italiane risultano particolarmente vulnerabili a causa delle risorse limitate da investire in cybersecurity, mentre la supply chain emerge come nuovo vettore critico di attacco, con un incremento del 34% degli incidenti che sfruttano i punti deboli della catena di fornitura.

Infine, il fattore umano si conferma ancora come il principale punto debole: secondo i dati Clusit, almeno un attacco su dieci potrebbe essere evitato con una migliore formazione del personale.

La cybersecurity non è più opzionale ma una necessità imprescindibile per la sopravvivenza e il successo di qualsiasi organizzazione moderna.